

-
File No.: EXP202201746

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On January 27, 2022, a complaint was received by the Spanish Agency for Data Protection (hereinafter, AEPD), submitted by A.A.A. (hereinafter, the complainant).

The complaint is directed against the CANARY ISLANDS HEALTH SERVICE with NIF Q8555011I (hereinafter, the respondent).

The reasons for the complaint are as follows:

The complainant states that there have been unauthorized accesses to her medical history and that her diagnosis has been disclosed to third parties.

She also states that the website of the Ministry of Health of the Government of the Canary Islands (<https://www.gobiernodecanarias.org/sanidad/>) uses cookies without notifying users or having a cookie policy and without requesting explicit consent for their use. They also do not have a Privacy Policy.

Date on which the reported events took place: November 2, 2021.

Relevant documentation provided by the complainant:

- Response issued by the CANARY ISLANDS HEALTH SERVICE regarding accesses to the Medical History, which includes a List of Accesses made by Primary Care from 10/5/21 to 12/9/2021 and a List of Accesses made by Specialized Care at the General Hospital of Fuerteventura from 10/6/2021 to 12/10/2021.

In this document, the complainant states that the accesses marked in color are not associated with any clinical process or consultation.

SECOND: In accordance with the preliminary mechanism for the admission of complaints submitted to the AEPD, as provided in Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD), which consists of forwarding them to the data protection delegates designated by the data controllers or processors, or to them when they have not designated any, and for the purpose indicated in the aforementioned article, the complaint was forwarded to the CANARY ISLANDS HEALTH SERVICE (hereinafter, the respondent) for analysis and response within one month, which was verified by a document received by this Agency on May 6, 2022.

In response to the transfer and request for information, the respondent stated that it had forwarded the complaint to the Security Office (ODS) of the Electromedical and Information Services Area (ASEI) and to the Management of Health Services of Fuerteventura.

The ASEI stated that it had audited the accesses marked by the complainant, requesting justification from the individuals who accessed such records. The Management of Health Services of Fuerteventura stated that, upon reviewing the files held by this management center, there was no documentation related to the reference file.

On April 25, the General Secretariat of the respondent sent the results of the audit conducted by the ASEI and informed the AEPD that a letter had been sent to all managements in the following terms:

"The Spanish Agency for Data Protection has sent, in a short period of time, several complaints regarding allegedly unauthorized accesses to the medical history of patients by personnel of the center.

Instruction No. 4/10 of this Directorate, regarding the actions of personnel of the Canary Islands Health Service who, in the course of their work, handle personal data, makes it clear that in the service-providing bodies, the head of the healthcare center will determine which units will adopt, on behalf of the data controller, the necessary measures for the personnel of each unit to understand, in a comprehensible manner, the security rules of the files that affect the development of their functions (fifth section).

In this regard, it is important that personnel accessing the medical history are aware of the disciplinary and even criminal responsibilities they may incur if, despite the warning already present in the

application, they access a patient's medical history for unjustified reasons.

Similarly, they are reminded that, upon any indication of unauthorized accesses, the corresponding management must take the necessary measures to clarify any administrative or criminal responsibilities that may arise."

The respondent also added that it was deemed appropriate to develop a protocol for processing requests received in which the interested party requests information about who accessed their medical history.

THIRD: On May 17, 2022, after analyzing the documentation in the file, a resolution was issued by the Director of the Spanish Agency for Data Protection, agreeing to archive the complaint.

The resolution was notified to the appellant on May 17, through the Electronic Notification Service and the Authorized Electronic Address as certified in the file.

FOURTH: On June 13, 2022, the complainant filed a discretionary appeal for reconsideration against said resolution, alleging that there have been unauthorized accesses to her medical history and disclosure of her health data to hospital staff regarding which no resolution has been made, stating that the Service

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/21

Canary Health only indicates that it "has audited the accesses marked by the claiming party," without justifying each of those accesses and the reasons that led the personnel in question to access them, as such accesses and movements in their clinical history are not associated with any clinical process or medical visit.

FIFTH: On July 27, 2022, the appeal filed was sent to the responding party in accordance with the provisions of Article 118.1 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) for the purpose of allowing them to formulate allegations and present the documents and justifications they deemed appropriate.

The transfer notification was sent on July 27, 2022, through the Electronic Notification Service and the Enabled Electronic Address as certified in the file, with no allegations submitted by the responding party regarding the statements made by the appellant in the filed appeal for reconsideration.

This procedure was notified on July 27, 2022, with no allegations received from the responding party as of the date of this resolution.

SIXTH: On October 6, 2022, the appeal for reconsideration filed by A.A.A. against the resolution of this Agency issued on May 17, 2022, which agreed to archive the complaint related to the CANARY HEALTH SERVICE, is upheld.

SEVENTH: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

The CANARY HEALTH SERVICE is framed within the DEPARTMENT OF HEALTH OF THE GOVERNMENT OF CANARY ISLANDS.

On December 5, 2022, the Data Inspection accessed the website of the DEPARTMENT OF HEALTH OF THE GOVERNMENT OF CANARY ISLANDS <https://www.gobiernodecanarias.org/sanidad/> verifying that it does not have a section on Privacy Policy. There is no record of data being collected on this website.

The website contains a cookie notice: "This website uses its own and third-party cookies to collect information that helps optimize your visit. Cookies are not used to collect personal information. You can change your settings whenever you wish. More information is available in our cookie policy."

Acceptance is not requested, and upon accessing the cookie policy, it states "Error 404. Document not found."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
4/21

On December 5, 2022, the Data Inspection accessed the website <https://www3.gobiernodecanarias.org/sanidad/scs/> of the CANARY ISLANDS HEALTH SERVICE, verifying that it has a Privacy Policy section in which it identifies itself as the data controller and includes, among other things, a link to the Activity Register of Processing that informs about the purpose, legal basis, recipients, and retention. Additionally, it includes a link to exercise the rights of the data subjects, the email address of the Data Protection Officer, and a link to the website of the Spanish Data Protection Agency.

In the Activity Register of Processing, the treatment CLINICAL HISTORY is listed, where the aforementioned information is provided.

Upon accessing the website of the CANARY ISLANDS HEALTH SERVICE, there is a notice about cookies: "The Canary Islands Health Service website uses its own and third-party cookies to collect information that helps optimize your visit. Cookies are not used to collect personal information. You can allow their use or reject it. You can also change your settings whenever you wish. More information is available in our cookie policy."

In the Cookie Policy, information is provided about technical cookies and analytical cookies, indicating: "Analytical cookies for tracking and statistical analysis of the behavior of all users. If these cookies are disabled, the website may continue to function, without prejudice to the fact that the information captured by these cookies about the use of our website and its content helps improve our services."

On December 9, 2022, the Data Inspection accessed the website of the HEALTH DEPARTMENT OF THE GOVERNMENT OF THE CANARY ISLANDS, verifying that it generates three cookies belonging to the Government of the Canary Islands. One of them is a session cookie, and the others, with expiration dates of 10-12-2022 and 13-01-2024, are from Google Analytics. (D cookies).

On the same date, the Data Inspection accessed the website of the CANARY ISLANDS HEALTH SERVICE, verifying that it generates four cookies belonging to the Government of the Canary Islands, with expiration dates: 9 and 10-12-2022 and 9 and 13-01-2024. Three of them are from Google Analytics. (D cookies).

In the actions AT/0724/2022, the complaint was forwarded to the HEALTH DEPARTMENT OF THE GOVERNMENT OF THE CANARY ISLANDS and the CANARY ISLANDS HEALTH SERVICE, being answered by the CANARY ISLANDS HEALTH SERVICE in the following terms:

It is noted that the complainant has not filed a complaint with the OFFICE OF SECURITY (ODS) OF THE AREA OF ELECTROMEDICAL SERVICES AND INFORMATION (ASEI) since, as stated at the end of the list provided by the complainant, it is indicated that "if any of the accesses included in the report may have been improper or unlawful, you can file a complaint so that the security office can carry out the necessary verifications to help clarify said access."

A report issued by the ODS has been provided regarding the audit conducted on the accesses made by PRIMARY CARE AND SPECIALIZED CARE AT FUERTEVENTURA GENERAL HOSPITAL, which reveals that the accesses were made by ten professionals, of which two of them...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
5/21

They accessed the history to inquire about the health status of the claimant since they identified her on the emergency list as she is a professional in the Anesthesia and Resuscitation Area (FEA).

Regarding cookies and the privacy policy, they state that they are working on it and provide drafts in this regard. These drafts are similar to those available on the website of the CANARY ISLANDS HEALTH SERVICE as of December 5, 2022, the date on which access was made from the Data Inspection.

The CANARY ISLANDS HEALTH SERVICE states and provides a written document regarding this matter, that the MANAGEMENT OF THE CANARY ISLANDS HEALTH SERVICE, the body responsible for the management of Clinical Histories, both in Primary Care and Specialized Care, has sent a written notice to all managements in the following terms: "The Spanish Agency for Data Protection has sent, in a short period of time, several complaints regarding allegedly improper accesses to the clinical history of patients by staff of the center. Instruction No. 4/10 of this Directorate... makes it clear that in the service-providing bodies, the person responsible for the healthcare center will determine which units will adopt, on behalf of the data controller, the necessary measures for the staff of each unit to understand, in a comprehensible manner, the security rules of the files that affect the development of their functions (fifth section). In this sense, it is important that the staff accessing the clinical history is aware of the disciplinary responsibilities... accesses the clinical history of a patient for unjustified reasons. Similarly, they are reminded that, in the event of any indication of improper accesses, the corresponding management must adopt the necessary measures to clarify the administrative or criminal responsibilities that may arise."

On December 12, 2022, a request for information was sent to the CANARY ISLANDS HEALTH SERVICE (hereinafter SCS), and from the response received, it is inferred:

Regarding the Security Policy

The SCS has provided a copy of the Security Policy, whose approval resolution was published in the Official Bulletin of the Canary Islands dated February 13, 2014, where the general criteria for security procedures are established (Document 1). All personnel must be informed of it as well as Instruction 04/2010 from the Director of the Canary Islands Health Service, related to the actions of staff who, by virtue of their job performance, handle personal data (Document 2). This instruction is mandatory reading and compliance for all personnel accessing the SCS systems, including the clinical history of patients.

The SCS states that when accessing for the first time, and in a sporadic and random manner, a notice appears on the screen reminding of the existence of said instruction and collects the consequent acceptance by the staff of their reading and understanding, and provides a screenshot of the mentioned notice where it is stated: "In the records of this Service, it does not appear that, as a worker providing services in the SCS and by virtue of the Personal Data Protection regulations, you have read and accepted Instruction 04/2010 of the Canary Islands Health Service regarding the actions of staff who handle personal data.

6/21

"Please read the instruction and click the corresponding button to continue" (Document 3).

The SCS has provided a copy of the Security Document (Document 4) which includes, among other aspects, information regarding the identification and authentication of users with access to information systems, and indicates that the technical managers of each application will be able to obtain the updated list of users as well as their access profiles. It also states that there will be an updated list of users with access to non-automated documents along with their access rights. Furthermore, regarding access control, it indicates that users will only access the resources necessary to perform their work. In the case of files containing high-level data, it is established, among other things:

- The information on accesses specified by the regulation will be retained.
- If access is authorized, information will be retained that allows for the identification of the record accessed by the user.
- The Security Officer will control the mechanisms of this record.

Security measures for the processing of CLINICAL HISTORIES

Access to the clinical history is regulated by Decree 178/2005, of July 26, which approves the Regulation governing clinical histories in hospital centers and establishments and establishes the content, conservation, and expurgation of their documents.

In Article 28 regarding the Procedure for recording access to the clinical history and its use, subsection 5 states: "The computerization, where applicable, of the procedure regulated in this article will guarantee the security, identification, and authentication of the persons accessing the information, as well as a record of such access, through the creation of the corresponding file, ensuring compliance with the provisions of the current legislation on the protection of personal data."

The SCS states that it has a file that records user activity in the various applications linked to the clinical history.

The SCS provides the document "Regulations for Logical Access Control" where the procedure for logical access control applicable to all personnel with access to the information held by the SCS is described (Document 6), which, as stated therein, meets the requirements of the National Security Scheme. In section 5 regarding Logical Access Control, it is noted that in addition to identification and authentication, the system, based on the identification and authentication data, provides the user with the necessary privileges for access to resources.

The SCS has also provided a copy of the Risk Analysis in which the treatments related to the Clinical History defined as Critical are listed and states that the security measures provided in the National Security Scheme are applied (Document 7). In this regard, they state that it is in the implementation and adaptation phase to Royal Decree 311/2022, of May 3, which regulates the National Security Scheme.

In relation to the clinical history of the Hospital of Fuerteventura, they have provided an audit of user management verification (Document 8), as well as the general audit of user management of the SCS (Document 9).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/21

In relation to the Data Protection Officer

The SCS states that "the Data Protection Officer performs their duties in accordance with Article 39 of the GDPR, primarily advising and supervising compliance with the current data protection regulations either ex officio or at the request of the involved service, assessing and informing on what they consider necessary for the proper processing of personal data."

EIGHTH. The subject of this file is the issue regarding possible unauthorized access to the claimant's medical history. The possible liability for the use of analytical cookies without obtaining user consent on the website of the Ministry of Health of the Government of the Canary Islands will, if applicable, be subject to a different procedure.

NINTH: On April 20, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the party being claimed, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR.

TENTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the party being claimed submitted a written statement of allegations on May 8, 2023, in which they stated that in relation to the infringement of Article 5.1 f) of the GDPR, in order to provide comprehensive and as complete assistance as possible, there is an electronic medical history (hereinafter HC), which must be accessed using a username and password, thus leaving the access logs to the different HCs recorded.

Currently, it is not technically feasible to restrict access to the HC of users solely to those healthcare professionals who are providing assistance at the exact moment to the patients, as there may be various cases in which it is necessary to access specialties, or tests requested and reviewed by another professional or center, or that during the assistance, a referral to another professional must be made. That is to say, to avoid compromising healthcare, it is not appropriate to completely restrict access to the HC.

From the audits conducted on 10 professionals, it has been confirmed that indeed, 2 of those accesses occurred without justified assistance, although it has not been proven that the information they accessed was disclosed by any means. Both professionals indicated that they became aware of

their colleague's admission because they saw her name on the emergency list. Therefore, they accessed her history to see if they could provide any knowledge from their specialty to assist in her recovery.

In relation to the alleged infringement of Article 32 of the GDPR, the entity being claimed states that it has been implementing the security measures that have been determined based on the treatments carried out, assessing in all cases the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/21

possible threats that could jeopardize the security of the processed information.

Being aware that absolute security does not exist, the SCS has been adopting security measures and conducting awareness-raising activities for its staff, which have proven effective up to this particular case.

Evidence of this review and the adoption of new measures is indicated in the publication of Instruction 6/2023 and the preparation of a new instruction for access to the HC by SCS personnel.

Likewise, when knowledge of these possible unauthorized accesses has been obtained, an internal audit has been conducted directed at the professionals involved, in order for them to justify the reason for the access, and from the corresponding Management, disciplinary instruction actions are being carried out to clarify possible responsibilities.

The entity being claimed concludes by stating that considering this is an isolated incident arising from the good faith of healthcare professionals to assist in the recovery of their colleague, additional necessary measures are being taken to further ensure the confidentiality of the information, and requests the filing of the proceedings.

ELEVENTH: On May 9, 2023, the instructor of the procedure agrees to reproduce for evidentiary purposes the complaint filed by A.A.A. and its documentation, the documents obtained and generated during the admission phase of the complaint, and the report of prior investigative actions that are part of the procedure.

Likewise, for evidentiary purposes, the allegations to the initiation agreement of the referenced sanctioning procedure presented by the CANARY ISLANDS HEALTH SERVICE, and the accompanying documentation are also reproduced.

TWELFTH: On May 30, 2023, a resolution proposal is issued in which it is proposed that the Director of the Spanish Agency for Data Protection issue a warning to the CANARY ISLANDS HEALTH SERVICE, with NIF Q8555011I, for each of the two infringements committed, one for the infringement of Article 5.1.f) of the GDPR and another for the infringement of Article 32 of the GDPR, both classified under Article 83.5 of the GDPR.

THIRTEENTH: On June 9, 2023, the following allegations are received from the entity being claimed in response to the resolution proposal:

“1st.- According to the provisions of Article 5.1 of the GDPR, it is determined that the data will be f) processed in such a way as to ensure an adequate level of security for personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures (“integrity and confidentiality”), it is considered that what...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/21

It is being asserted that the SCS does not process data in a manner that guarantees the application of the principles set forth in the aforementioned provision, and they do not agree with this assertion. Considering the type of services provided by the SCS to users, and in order for healthcare to be as

comprehensive and complete as possible, there is an electronic clinical history (hereinafter HC) to which healthcare professionals can access using a username and password, and whose access logs are recorded. Currently, and due to the activity of the SCS, it is not technically feasible to restrict access to the HC of users solely to those healthcare professionals who are providing assistance at the exact moment to the patients, as there may be various cases in which it is necessary to access specialties, or tests requested and reviewed by another professional or center, or where a referral to another professional must be made during the assistance.

Nevertheless, in the interest of exercising proactive responsibility, the SCS is developing an instruction to try to limit access to the HC as much as possible, based on the previously stated premise that it is not possible to have restricted access to the HC to ensure the agility with which healthcare services must be provided.

In this new instruction from the SCS Directorate, guidelines are being provided to implement the justification of access to the HC when, for example, the user does not belong to the professional's assigned patient list or is not being attended to by this professional in emergencies or in any specialty (the latest draft of the access instruction to the HC is attached as Doc. 1), as requested by the complainant to a colleague to know the status of tests or to try to expedite administrative procedures. Apart from this, the SCS is conducting awareness and training activities for staff and has recently published an update to the previous Instruction 4/2010, Instruction No. 6/2023 from the Director of the Canary Islands Health Service, regarding the processing of personal data carried out by the staff of the Canary Islands Health Service in the performance of their job, which has been disseminated among the staff and is accessible on the intranet (attached as Doc. 2).

For the reasons stated, it is not considered appropriate to assert that

a) The processing of personal data is being carried out in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679, as the data controller, the SCS, has adopted measures aimed at ensuring the confidentiality of the data contained in the electronic HC, with various notices upon logging in, raising awareness among staff about the need to maintain confidentiality and access only what is strictly necessary for the performance of their functions, etc., measures that are currently being reinforced with the new Access Instruction to the HC pending approval.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/21

According to the information provided by the AEPD, the complainant claims that the health information related to her person has been disclosed to third parties by the professionals who accessed her medical record (HC), although this fact is not substantiated beyond the assertion of the party and without confirmation of this fact by the professionals when requested during the directed audit conducted with them, which is why this assertion is not proven and should not be taken into consideration.

2nd.- On the other hand, a sanction is imposed for non-compliance with Article 32, which states that “1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks to the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others: [...]

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;”

Well, the SCS has been implementing the security measures that have been determined based on the treatments carried out, assessing in all cases the possible threats that could jeopardize the security of the processed information.

In the analyses conducted, the human factor has always been and is taken into account as one of the present threats in any processing; appropriate countermeasures have been applied to mitigate this risk, which, to date, have proven effective, although this particular case has demonstrated that they are

not infallible.

Therefore, determining that technical and organizational measures have not been applied to ensure the confidentiality of the information and sanctioning for it is considered excessive, since measures have been established based on the analyzed risks, although, as previously indicated, they have been shown to be not invulnerable.

Being aware that absolute security does not exist, the SCS has been adopting security measures and conducting awareness-raising activities for its staff that have demonstrated their effectiveness until this particular case, among others, with the publication of Instruction 6/20PS/00587/2021, a PS open to the MADRID HEALTH SERVICE.

23 and the development of a new instruction for access to the HC by SCS personnel.

3rd.- A double sanction is applied for the same fact, since it is proposed to sanction the infringement of Article 5.1.f) of the GDPR as very serious and the infringement of Article 32 of the GDPR as serious, among whose measures is already the guarantee of the confidentiality of the information, which results in the duplication of the sanction for the alleged act committed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/21

For all the above, and considering that this is an isolated incident arising from the good faith of the healthcare professionals to assist in the recovery of their colleague, and that measures are being taken to reinforce the guarantee of confidentiality of the information, WE REQUEST the filing of the proceedings.”

In view of all that has been acted upon, the Spanish Agency for Data Protection considers the following facts to be proven in the present procedure,

PROVEN FACTS

FIRST: Unauthorized access to the complainant's medical record has occurred, which makes it possible to disclose such personal data to third parties despite not having the consent of the data subject.

SECOND: The entity being complained against has provided a report issued by the Office of Security (ODS) of the Area of Electromedical and Information Services (ASEI) regarding the audit conducted on the accesses made by Primary Care and Specialized Care at the General Hospital of Fuerteventura, which reveals that the accesses were made by ten professionals, of whom two accessed the record to inquire about the health status of the complainant as they identified her on the emergency list since she is a professional in the Anesthesia and Resuscitation Area (FEA).

LEGAL GROUNDS

I

In accordance with the provisions of Articles 58.2 and 60 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, regarding the protection of natural persons with regard to the processing of personal data and the free movement of such data (GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 and 68.2 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

II

Regarding health data, Recital 35 of the GDPR states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

"Among the personal data related to health, all data regarding the health status of the data subject that provides information about their physical or mental health, past, present, or future, must be included. This includes information about the individual collected during their registration for healthcare purposes, or during the provision of such assistance, in accordance with Directive 2011/24/EU of the European Parliament and of the Council; any number, symbol, or data assigned to an individual that uniquely identifies them for health purposes; information obtained from tests or examinations of a part of the body or a bodily substance, including data from genetic information and biological samples, and any information related, for example, to a disease, a disability, the risk of suffering from diseases, medical history, clinical treatment, or the physiological or biomedical status of the data subject, regardless of its source, for example, a doctor or other healthcare professional, a hospital, a medical device, or an in vitro diagnostic test."

For its part, Article 4 of the GDPR defines:

"2) 'processing': any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or any other form of making available, comparison or interconnection, restriction, erasure or destruction;

7) 'data controller' or 'controller': the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its designation may be provided by the law of the Union or of the Member States;

10) 'third party': a natural or legal person, public authority, service, or body other than the data subject, the controller, the processor, and the persons authorized to process the personal data under the direct authority of the controller or the processor;"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

III

The processing of data from medical records is regulated by Law 41/2002, of November 14, which is the basic regulation governing patient autonomy and rights and obligations regarding information and clinical documentation.

Its Article 3 states:

"Medical record: the set of documents that contain data, assessments, and information of any kind regarding the situation and clinical evolution of a patient throughout the care process."

In Article 16, the uses of the medical record are established:

"1. The medical record is an instrument primarily intended to guarantee adequate care for the patient. The healthcare professionals at the center who perform the diagnosis or treatment of the patient have access to the medical record as a fundamental instrument for their proper care.

2. Each center shall establish methods that enable access to the medical record of each patient by the professionals assisting them at all times."

IV

The principles relating to the processing of personal data are regulated in Article 5 of the GDPR, which establishes that "personal data shall be:

"a) processed lawfully, fairly, and in a transparent manner in relation to the data subject ('lawfulness, fairness, and transparency');

b) collected for specified, legitimate purposes and not further processed in a manner that is incompatible with those purposes; in accordance with Article 89, paragraph 1, further processing of

personal data for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes shall not be considered incompatible with the initial purposes ('purpose limitation');
c) adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed ('data minimization');

d) accurate and, where necessary, kept up to date; all reasonable steps must be taken to ensure that personal data that are inaccurate with respect to the purposes for which they are processed are erased or rectified without delay ('accuracy');

e) kept in a form which permits identification of data subjects for no longer than is necessary for the purposes of the processing of personal data; personal data may be stored for longer periods as long as they are processed solely for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes, in accordance with Article 89, paragraph 1, without prejudice to the application of appropriate technical and organizational measures that..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/21

imposes this Regulation in order to protect the rights and freedoms of the data subject ("limitation of the retention period");

f) treated in such a way as to ensure an adequate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ("integrity and confidentiality").

The data controller shall be responsible for compliance with the provisions of paragraph 1 and capable of demonstrating it ("proactive accountability").

V

In the present case, a complaint is presented regarding unauthorized access to the medical history and the disclosure to third parties of the diagnosis of the complainant.

In relation to the unauthorized accesses, the entity has provided:

- Report issued by the Security Office (ODS) of the Area of Electromedical Services and Information (ASEI) regarding the audit conducted on the accesses made by Primary Care and Specialized Care at the General Hospital of Fuerteventura, which reveals that the accesses were made by ten professionals, of whom two accessed the history to inquire about the health status of the complainant as they identified her on the emergency list since she is a professional in the Area of Anesthesia and Resuscitation (FEA).
- There is no record that the complainant has made a complaint to the ODS.

In relation to the security of the treatments, the entity has provided:

- Security Policy, whose approval resolution was published in the Official Bulletin of the Canary Islands on February 13, 2014.
- Instruction 04/2010 from the Director of the CANARY ISLANDS HEALTH SERVICE, regarding the actions of personnel who, by virtue of their job performance, process personal data.
- Security document.
- Decree 178/2005, of July 26, which approves the Regulation governing the medical history in hospitals and healthcare establishments and establishes the content, retention, and purging of its documents.
- Regulations for logical access control in accordance with the National Security Scheme.
- Risk Analysis in which the treatments related to the Medical History defined as Critical are listed and indicate that the security measures provided in the National Security Scheme are applied.

As indicated in the legal basis III, from the reading of Article 16 of Law 41/2002, of November 14, which regulates the autonomy of the patient and rights and obligations regarding information and clinical documentation, it is clearly inferred that, while the medical history is the instrument for

providing healthcare to the patient, what must be duly guaranteed is also the fact that access to the medical history can only occur by the professionals who assist the patient, not generally, but specifically for the diagnosis or treatment of the patient.

Despite the technical and organizational measures implemented, access to a patient's medical history by third parties has not been prevented, which indicates the absence of measures that ensure adequate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures.

Regarding the principle of data protection by design, the GDPR requires in its Article 25:

"1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity posed by the processing to the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of data subjects."

Therefore, it is considered that such facts constitute a breach of confidentiality, thereby violating Article 5.1 f) of the GDPR, which governs the principle of integrity and confidentiality, as unauthorized accesses to the medical history have occurred, compromising the confidentiality of the health data it contains by allowing access by third parties who were not authorized to do so.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/21

The criterion of the AEPD regarding this type of unauthorized access has a clear precedent, produced in a sanctioning procedure processed after the entry into force of the GDPR. This is the case file reference PS/00250/2021, in which the EXTREMADURA HEALTH SERVICE was sanctioned for a problem identical to that which concerns us in this file. The narration of the facts states:

"The inspection actions are initiated by the receipt of a complaint from A.A.A. (hereinafter, the complainant), in which he states that there have been unauthorized accesses to his medical history by a worker of the Extremadura Health Service (hereinafter SES), with a professional category of nurse. The accesses are made without the complainant's authorization and without any relationship that justifies it."

Therefore, this Agency considers that the reported facts, consisting of the disclosure of the complainant's medical data to unauthorized persons, constitute a violation of Article 5.1.f) of the GDPR.

VI

The violation of Article 5.1.f) of the GDPR entails the commission of the infringements typified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

For the purposes of the limitation period, Article 72.1 a) of the LOPDGDD states that "based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a three-year limitation period: those that involve a substantial

violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679.”

VII

On the other hand, the security in the processing of personal data is regulated in Article 32 of the GDPR, which establishes the following:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probability and severity risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/21

measures to ensure an adequate level of security commensurate with the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
 - b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
 - c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
 - d) a process for regular verification, evaluation, and assessment of the effectiveness of technical and organizational measures to ensure the security of processing.
2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.
3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.
4. The data controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.”
- Recital 75 of the GDPR lists a series of factors or situations associated with risks to the guarantees of the rights and freedoms of data subjects:

“The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing could lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal racial or ethnic origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, data concerning health, or data concerning a person's sex life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/21

to use personal profiles; in cases where personal data of vulnerable individuals, particularly children, is processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects.”

The violation of Article 32 of the GDPR constitutes the commission of the infringements specified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to up to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

For the purposes of the statute of limitations, Article 73.g) of the LOPDGDD, under the heading “Serious infringements” provides:

“Based on Article 83.4 of Regulation (EU) 2016/679, the following infringements shall be considered serious and shall be subject to a two-year limitation period:

g) The breach, as a result of a lack of due diligence, of the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679.”

VIII

In this case, this Agency has established that the security measures of the entity being complained about are inadequate, which constitutes a violation by the entity of the provisions of Article 32 of the GDPR.

The failure to adopt measures to ensure the principle of confidentiality means that it cannot be considered that there are measures that provide an adequate level of protection against existing risks; this is because the established Security Policy is based on a resolution dated February 13, 2014, an Instruction from 2010 issued by the Director of the CANARY ISLANDS HEALTH SERVICE, and Decree 178/2005, of July 26, which approves the Regulation governing the clinical history in hospital centers and establishments and establishes the content, preservation, and purging of its documents, all of which are norms predating the current regulations on data protection, whose core is based on the GDPR 2016/679, in force since May 25, 2018.

Therefore, by failing to adopt the necessary security measures to ensure the protection of the personal data of the patients of this health service, it is considered that Article 32 of the GDPR has been violated.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

19/21

IX

In conclusion, it should be noted that according to the evidence available, it is considered that the entity being complained about has processed personal data of the complainant, their clinical history and diagnosis, allowing access without adopting the appropriate technical or organizational measures, which implies a violation of Article 5.1 f) of the GDPR, nor have the security measures required by the regulations on personal data protection been adopted, leading to a violation of Article 32 of the GDPR. In light of these facts, this Agency considers that the entity being complained about has infringed Articles 5.1 f) and 32 of the GDPR, by violating the principle of integrity and confidentiality, as well as failing to adopt the necessary security measures to ensure the protection of the personal data of the patients of this health service.

Therefore, this procedure concludes with the imposition of two sanctions for these facts: one for the violation of Article 5.1.f) GDPR, and another for Article 32 GDPR.

X

Article 58.2 of the GDPR provides as follows: “Each supervisory authority shall have all of the following

corrective powers:

b) to issue a warning to any controller or processor when the processing operations have infringed the provisions of this Regulation;

d) to order the controller or processor to bring the processing operations into compliance with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time;

i) to impose an administrative fine in accordance with Article 83, in addition to or instead of the measures mentioned in this paragraph, depending on the circumstances of each particular case;

XI

Article 83 “General conditions for the imposition of administrative fines” of the GDPR in its paragraph 7 establishes:

“Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State.”

Furthermore, Article 77 “Applicable regime for certain categories of controllers or processors” of the LOPDGDD provides, in accordance with the wording in force at the time the facts occurred, the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/21

“1. The regime established in this article shall apply to the treatments for which the following are responsible or in charge:

d) Public bodies and entities of public law linked to or dependent on the Public Administrations.

2. When the responsible parties or those in charge listed in section 1 commit any of the infractions referred to in articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed.

The resolution shall be notified to the responsible party or the person in charge of the treatment, to the body to which they hierarchically depend, if applicable, and to the affected parties who have the status of interested parties, if applicable.

3. Without prejudice to what is established in the previous section, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that is applicable.

Furthermore, when the infractions are attributable to authorities and executives, and it is proven that there are technical reports or recommendations for the treatment that have not been duly addressed, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order the publication in the Official State Gazette or the corresponding regional gazette.

4. The resolutions related to the measures and actions referred to in the previous sections shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.”

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DIRECT to the CANARY ISLANDS HEALTH SERVICE, with NIF Q8555011I, for an infringement of article 5.1.f) of the GDPR and article 32 of the GDPR, classified under article 83.5 and 83.4 of the GDPR respectively, a warning sanction for each infringement committed.

SECOND: TO NOTIFY this resolution to the CANARY ISLANDS HEALTH SERVICE.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid
sedeagpd.gob.es

21/21

THIRD: TO PROPOSE the initiation of disciplinary actions against the medical professionals who accessed the claimant's medical history.

FOURTH: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of article 77.5 of the LOPDGDD.

In accordance with the provisions of article 50 of the LOPDGDD, this Resolution shall be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with art. 48.6 of the LOPDGDD, and in accordance with the provisions of article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of art. 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with the documentation that proves the effective filing of the administrative contentious appeal. If the Agency does not have knowledge of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

938-181022

Mar España Martí
Director of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es